Module 4: Application Layer and Network Security

HTTP, FTP, SMTP, DNS and DHCP; cryptography, firewalls and VPNs;
SSL/TLS and IPSec

Exam: Wednesday 18 November 2026

Exam Focus

Scope. Syllabus 4.1 to 4.4: overview of the application layer; protocols HTTP, FTP, SMTP, DNS and DHCP; introduction to network security — cryptography, firewalls and VPNs; and security protocols SSL/TLS and IPSec.

This module carries CO4 and is the whole of the October CAE-II. Every part of it has appeared at least once. The application layer half is descriptive and cheap; the security half is where the comparisons earn marks.

Contents

1 The application layer 2

2 HTTP 2

3 FTP 3

4 Electronic mail 3

5 DNS 4

6 DHCP 5

7 Cryptography 5
- 7.1 Symmetric versus asymmetric . . . 6
- 7.2 RSA, worked . . . 6
- 7.3 Hashing and digital signatures . . . 7

8 Firewalls 7

9 VPNs 8

10 Security protocols 8
- 10.1 SSL/TLS . . . 8
- 10.2 IPSec . . . 9

11 Answer skeletons 10

12 Self-test 10

13 Last-minute page 11

The application layer

Past-paper question

Oct 2025 Q4(a)(ii). What is the main function of the Application Layer in the OSI model?

Solution

The application layer is the only layer that interacts directly with the user's software. Its function is to **provide network services to application processes**: it defines the protocols by which programs exchange meaningful data, and it handles the user-facing semantics of the exchange.

It does *not* route, frame or transmit. It specifies **what** is said and **in what form**: the message syntax, the meaning of each field, and the dialogue rules.

Service	Protocol
Web access	HTTP, HTTPS
File transfer	FTP, SFTP, TFTP
Electronic mail	SMTP (send), POP3 and IMAP (retrieve)
Name resolution	DNS
Address configuration	DHCP
Remote login	SSH, Telnet
Network management	SNMP
Time synchronisation	NTP

Architecturally: almost every application protocol is a client–server dialogue. The server listens on a well-known port; the client uses an ephemeral port. Peer-to-peer designs (BitTorrent) relax this but keep the same message formats.

HTTP

HTTP is a stateless request–response protocol that carries the resources of the web. The client sends a request; the server sends a response; the connection state is not retained between requests.

Aspect	Detail
Port	80 (443 for HTTPS)
Methods	GET, POST, PUT, DELETE, HEAD, OPTIONS, PATCH
Status classes	1xx information, 2xx success (200 OK), 3xx redirect (301, 302), 4xx client error (400, 403, 404), 5xx server error (500, 503)
Statelessness	Each request is independent; state is added by cookies and sessions
Non-persistent	One TCP connection per object: 1 RTT to connect plus 1 RTT per object
Persistent	One connection for many objects; saves a connection set-up per object
HTTP/2	Multiplexed streams over one connection, header compression, server push
HTTP/3	Runs over QUIC (UDP) to remove TCP head-of-line blocking

Past-paper question

Oct 2025 CAE-II Q2A(d). Describe how HTTP handles multiple simultaneous requests when employees browse different websites at the same time.

Solution

Browsers open several **parallel TCP connections** to a server (historically up to six per host) so that a slow object does not block the others. Each connection is identified by its own four-tuple, so the server can keep them apart.

That approach has costs: six connections means six slow starts and six sets of congestion state. Modern solutions:

- **HTTP/1.1 pipelining and persistent connections**: reuse one connection, but responses are still ordered, so a large object blocks those behind it (head-of-line blocking at the application level).
- **HTTP/2**: one connection carries many *streams* multiplexed with binary framing; a blocked stream does not block the others. It also compresses headers (HPACK) and supports server push.
- **HTTP/3 over QUIC**: the same multiplexing but over UDP, so a lost packet stalls only its own stream, not the whole connection.

To different websites: the browser resolves each hostname by DNS (possibly in parallel), then opens connections per origin. Browsers limit connections *per origin*, so many small origins are used deliberately as a performance trick (domain sharding), though HTTP/2 makes that counterproductive.

FTP

Past-paper question

Oct 2025 CAE-II Q2A(b). For the file transfer requirement, explain how FTP modes (active and passive) affect connectivity if employees are behind a firewall.

Solution

FTP uses **two** TCP connections:

- **Control connection**, port 21: carries commands and replies for the whole session.
- **Data connection**, port 20 in active mode: carries the file, opened per transfer.

Mode	Who opens the data connection	Effect behind a firewall
Active	The **server** connects back to the client on a port the client nominated	The firewall sees an unsolicited inbound connection and blocks it. Requires a pinhole or an FTP-aware firewall.
Passive	The **client** opens the data connection to a port the server nominated	Works through NAT and most firewalls, because all connections are outbound.

The practical answer for the scenario: use **passive mode**. Active mode fails for employees behind NAT because the server's inbound connection cannot reach a private address and the firewall drops it. Passive mode keeps every connection client-initiated, so stateful firewalls permit it automatically.

The larger point worth stating: FTP is plaintext. Credentials and files cross the network readable. The correct modern answer to "employees need to upload and download files" is **SFTP over SSH** or **FTPS**, not FTP with a clever mode.

Electronic mail

Protocol	Port	Role
SMTP	25 (587 submission)	*Push*: transfers mail from client to server and server to server. The sending protocol.
POP3	110	*Pull*: downloads mail and typically deletes it from the server. Single device.
IMAP	143	*Pull*: keeps mail on the server and synchronises state and folders across devices.

Past-paper question

Oct 2025 CAE-II Q2A(c). If an employee tries to send an email but it does not reach the recipient, explain how you would troubleshoot using SMTP concepts.

Solution

SMTP works in three hops: client to submission server, server to server across the Internet, and finally delivery to the recipient's mailbox. Diagnose in that order.

1. **Is it a submission failure?** The client would report an error immediately. Check the submission port (587 with STARTTLS, or 465 with implicit TLS), authentication, and whether the server requires TLS. A blocked port 25 outbound is a very common cause: ISPs and corporate networks block it to stop spam.
2. **Read the SMTP reply code.** Codes are three digits:
   - `2xx` success (250 OK, 251 forwarded)
   - `4xx` temporary failure, retry later (421 service unavailable, 450 mailbox busy, 451 local error)
   - `5xx` permanent failure, bounce (550 mailbox unavailable, 551 not local, 554 transaction failed)

   A 5xx means the message will not be retried; the sender gets a bounce. A 4xx means it sits in the queue and is retried for typically 3–5 days.
3. **Is it a relaying problem?** The server may refuse to relay for a domain it is not responsible for ("relaying denied"). Check that the sending server is authorised for the domain with SPF, and that DKIM and DMARC are configured, otherwise the receiver may silently discard the message as spam.
4. **Is it a DNS problem?** No MX record for the recipient domain means no server to deliver to. `dig MX recipient.com` answers this.
5. **Is it in the queue?** Inspect the mail queue (`mailq`); a growing queue with 4xx codes points at the receiving side or a network path.
6. **Was it filtered?** `550 5.7.1 message rejected as spam` means the receipt was refused. Check blacklists and authentication.

The diagnostic shape for the exam: name the three hops, name the reply-code classes, and give one concrete check per hop.

DNS

Past-paper question

Oct 2025 Q4(b)(iii). Explain how DNS resolves a domain name to an IP address step by step.

Solution

DNS is a hierarchical, distributed database that maps names to addresses. It is required because humans use names and routers need numbers.

The hierarchy: root servers (13 logical roots, served by hundreds of anycast instances) → top-level domain servers (`.com`, `.org`, `.in`) → authoritative servers for the domain.

Stages of a resolution for `www.example.com`:

1. The application calls the **stub resolver** in the OS, which asks the **recursive resolver** (usually the ISP's, or 8.8.8.8, or 1.1.1.1).
2. The resolver checks its **cache**. If a valid entry exists, it answers immediately. If not:
3. The resolver asks a **root server**: "who handles `.com`?" The root returns a *referral* to the `.com` TLD servers.
4. The resolver asks the `.com` **TLD server**: "who handles `example.com`?" It returns a referral to the domain's authoritative name servers.
5. The resolver asks the **authoritative server** for `example.com`: "what is `www.example.com`?" It returns the **A record** with the IP address.
6. The resolver caches the answer for the record's **TTL** and returns it to the stub resolver, which passes it to the application.

Record	Meaning
A	IPv4 address
AAAA	IPv6 address
CNAME	Alias to another name
MX	Mail server for the domain, with a preference value
NS	Authoritative name server for the zone
TXT	Arbitrary text, used for SPF, DKIM, verification
PTR	Reverse lookup: address to name
SOA	Start of authority: zone metadata

Recursive versus iterative queries. A *recursive* query asks the resolver to do all the work and return the final answer; that is what the client sends. The resolver's own queries to root, TLD and authoritative servers are *iterative*: each returns the next referral.

Port 53, over UDP for normal queries and TCP for zone transfers and large responses.

DHCP

DHCP assigns IP configuration automatically: address, subnet mask, default gateway, DNS servers, and lease duration.

Exam Focus

DORA: the four-message exchange.

1. **Discover**: client broadcasts "is there a DHCP server?" (source 0.0.0.0, destination 255.255.255.255).
2. **Offer**: a server offers an address and parameters.
3. **Request**: the client broadcasts which offer it accepts.
4. **Acknowledge**: the server confirms the lease.

The lease has a duration and must be renewed (at 50% of the lease by unicast, at 87.5% by broadcast). If no server answers, the client self-assigns a link-local address in `169.254.0.0/16` — which is exactly the symptom of a DHCP failure.

Aspect	DNS / DHCP
Purpose	DNS maps names to addresses; DHCP assigns addresses and configuration
Model	DNS is distributed and hierarchical; DHCP is a local broadcast service
Port	DNS 53; DHCP 67 (server) and 68 (client)
Transport	DNS UDP (and TCP); DHCP UDP broadcast
State	DNS caches with TTL; DHCP leases with a duration

Cryptography

Past-paper question

Oct 2025 Q4(a)(i). Define cryptography and list its main goals. Differentiate between plaintext, ciphertext, and key.

Solution

Cryptography is the science and practice of securing information by transforming it so that only authorised parties can read it and verify its origin and integrity.

Goals:

Goal	Meaning
Confidentiality	Only the intended recipient can read the data. Achieved by encryption.
Integrity	The data has not been altered. Achieved by hashes and MACs.
Authentication	The sender is who they claim to be. Achieved by signatures and certificates.
Non-repudiation	The sender cannot later deny having sent the message. Achieved by digital signatures only.
Access control	Only authorised parties may use the resource.
Availability	The service remains usable, including under attack.

The three terms:

- **Plaintext** is the original, readable message.
- **Ciphertext** is the unreadable output of encryption.
- A **key** is the secret parameter that controls the transformation; the algorithm is public, the key is not. Kerckhoffs's principle: security must rest on the key alone.

$$C = E_K(P), \qquad P = D_K(C).$$

Symmetric versus asymmetric

Basis	Symmetric	Asymmetric (public key)
Keys	One shared secret	A key pair: public and private
Speed	Very fast, suited to bulk data	Very slow, roughly a thousand times slower
Key distribution	Hard: the shared secret must be transmitted securely	Easy: the public key is published
Non-repudiation	Not possible, either party could have made the message	Possible, only the private-key holder could sign
Examples	AES, DES, 3DES, ChaCha20	RSA, ECC, Diffie–Hellman, ElGamal
Typical use	Encrypting the payload	Key exchange and digital signatures

Remember

How the two are used together. Asymmetric cryptography solves key distribution; symmetric solves speed. Real protocols use both: a TLS handshake uses asymmetric operations (and Diffie–Hellman) to agree a *session key*, and the session key then encrypts the whole conversation symmetrically. That hybrid is the single most useful sentence in this module.

RSA, worked

Exam Focus

Worked, small RSA. Choose $p = 3$, $q = 11$. Encrypt $M = 5$.

Solution

1. $n = p \times q = 33$.
2. $\phi(n) = (p-1)(q-1) = 2 \times 10 = 20$.
3. Choose e coprime to ϕ: $e = 3$.
4. Compute d with $e\,d \equiv 1 \pmod{\phi}$: $3 \times 7 = 21 \equiv 1 \pmod{20}$, so $d = 7$.
5. Public key $(e, n) = (3, 33)$; private key $(d, n) = (7, 33)$.
6. Encrypt: $C = M^e \bmod n = 5^3 \bmod 33 = 125 \bmod 33 = \mathbf{26}$.
7. Decrypt: $M = C^d \bmod n = 26^7 \bmod 33 = \mathbf{5}$. Correct.

Why it is secure: an attacker knows n and e. Factoring $n = 33$ is trivial here, but for a 2048-bit n it is computationally infeasible, so d cannot be recovered. That is the whole basis of RSA.

Hashing and digital signatures

A **cryptographic hash** maps any input to a fixed-length digest and must be:

- **one-way** (pre-image resistant): you cannot recover the input,
- **collision resistant**: you cannot find two inputs with the same digest,
- **avalanche**: one bit changed alters about half the output bits.

Examples: SHA-256, SHA-3. MD5 and SHA-1 are broken and must not be used.

Exam Focus

A digital signature, in four steps.

1. The sender hashes the message: $h = H(M)$.
2. The sender encrypts the hash with their *private* key: $S = E_{priv}(h)$.
3. The message and S are sent.
4. The receiver decrypts S with the sender's *public* key to get h, recomputes $H(M)$, and compares.

A match proves **integrity** (the message was not changed) and **authentication** (only the private-key holder could have produced S) and gives **non-repudiation**.

Do Not Confuse

Signing encrypts with the private key; encrypting for confidentiality uses the public key. Students invert this constantly. Private key = prove who I am. Public key = let only me read it.

Firewalls

Past-paper question

Oct 2025 Q4(b)(ii). Explain how firewalls filter packets based on security rules.

Solution

A **firewall** is a device or software that enforces an access control policy between networks, permitting or denying traffic according to rules.

Type	How it works	Limitation
Packet filter (stateless)	Examines each packet's header independently: source and destination IP, port, protocol, flags. Applies an ordered rule list, first match wins.	No awareness of connections, so it cannot distinguish a reply from an unsolicited packet; vulnerable to spoofing and fragmentation tricks.
Stateful inspection	Keeps a connection table; a packet is allowed if it belongs to an established session. Return traffic is permitted automatically.	More memory and CPU; cannot inspect encrypted payloads.
Application proxy / gateway	Terminates the connection and re-originates it, inspecting the payload at layer 7; can filter HTTP methods, URLs and malware.	Slow; each service needs its own proxy.
Next-generation firewall	Combines stateful filtering with deep packet inspection, intrusion prevention and application identification.	Cost and complexity.

A rule table, evaluated top to bottom, first match wins:

No.	Action	Source	Destination	Service
1	Allow	any	10.0.0.10	HTTP, HTTPS
2	Allow	10.0.0.0/24	any	DNS
3	Allow	10.0.0.0/24	any	SMTP
4	Deny	any	any	any

The design principle: default deny. The last rule must be an explicit deny; anything not permitted is dropped. Placement matters too: a **screened subnet** (DMZ) holds public servers between two firewalls, so a compromised web server does not expose the internal network.

What a firewall cannot do: stop an insider, stop traffic that arrives over an allowed port (HTTP on 443), or inspect traffic it cannot decrypt. That is why it sits alongside IDS/IPS, authentication and endpoint protection.

VPNs

A **VPN (Virtual Private Network)** carries private traffic over a public network by **tunnelling**: the original packet is encrypted and wrapped inside a new packet that can cross the Internet.

Property	How it is provided
Confidentiality	Encryption of the payload
Integrity	Message authentication over each packet
Authentication	Of both endpoints, using certificates or pre-shared keys
Addressing	The tunnelled packet keeps its private addresses; the outer packet uses public ones

Three common forms:

- **Remote access VPN**: an individual connects to a corporate gateway. TLS-based (OpenVPN, WireGuard arrangements) or IPSec.
- **Site-to-site VPN**: two office networks joined as if on one link.
- **SSL/TLS VPN**: runs in the browser, nothing to install, so it works from anywhere.

Security protocols

SSL/TLS

Past-paper question

Oct 2025 Q4(a)(iii). Describe the main objective of SSL/TLS protocols.

Solution

SSL (superseded) and **TLS** sit between the application and the transport layer, providing a secure channel over TCP.

Objectives:

1. **Confidentiality**: encrypt the application data with a negotiated symmetric session key.
2. **Integrity**: a MAC over each record detects modification.
3. **Authentication**: the server (and optionally the client) proves its identity with an X.509 certificate signed by a trusted CA.

The handshake, simplified:

1. **ClientHello**: supported versions, cipher suites, a random nonce.
2. **ServerHello**: chosen version and cipher suite, a random nonce, and the server **certificate**.
3. The client validates the certificate chain against its trust store and checks the name and dates.

4. **Key exchange**: Diffie–Hellman (preferably ephemeral, giving forward secrecy) or RSA key transport, producing a shared master secret.
5. **Finished**: both sides send a MAC over the handshake transcript, proving nothing was tampered with.
6. Data flows encrypted with the session key, using an AEAD cipher such as AES-GCM.

Forward secrecy is the property that compromising the server's long-term private key later does not decrypt recorded past sessions, because the ephemeral keys are gone. That is why ECDHE is mandatory in TLS 1.3.

Where it is used: HTTPS, SMTPS/IMAPS, FTPS, and as the transport for VPNs and API calls. TLS 1.3 removed weak ciphers and cut the handshake to one round trip.

IPSec

IPSec secures IP itself, at layer 3, so every application is protected without modification.

Component	Role
AH (Authentication Header)	Integrity and authentication of the whole packet including the IP header. *No confidentiality.*
ESP (Encapsulating Security Payload)	Confidentiality plus integrity and authentication of the payload. The usual choice.
IKE	Negotiates the security association: algorithms, keys, lifetime.

Mode	What is protected	Use
Transport mode	The payload only; the original IP header is intact	Host-to-host, e.g. two servers
Tunnel mode	The whole original packet is encrypted and wrapped in a new one	Site-to-site VPN, gateway to gateway

Basis	SSL/TLS	IPSec
Layer	Between transport and application (layer 4–5)	Network layer (layer 3)
Transparency	Applications must use it (HTTPS, SMTPS)	Transparent to all applications
Transport	Requires TCP	Works over IP, so also UDP
Typical use	Web, mail, API	VPNs, site-to-site links

Past-paper question

Oct 2025 Q4(b)(i). Discuss the vulnerabilities associated with HTTP and FTP. Propose secure alternatives and explain how it mitigates risks.

Solution

Protocol	Vulnerability	Mitigation
HTTP	Plaintext: credentials, cookies and content readable by anyone on the path. No integrity. Easy to inject content.	HTTPS (TLS): confidentiality, integrity, server authentication; HSTS forces it.
FTP	Plaintext credentials and data. Two-port design defeated by firewalls and NAT. Anonymous access often left enabled.	SFTP over SSH, or FTPS. Disable anonymous access.
Both	No protection against replay or downgrade	TLS with authenticated encryption; certificate pinning; disable weak protocol versions

How the mitigation works, in one sentence each. TLS encrypts the payload so an eavesdropper on the path sees only ciphertext; the MAC prevents silent modification; the certificate proves the server is the one it claims to be, defeating impersonation and most man-in-the-middle attacks.

Answer skeletons

Answer Skeleton

Application protocol question (10 marks). Name the port, the transport (TCP or UDP), the message sequence with the actual commands or reply codes, and one security weakness with its fix. Ten marks is about a diagram, a sequence and a comparison.

Answer Skeleton

Security question (10 marks). State the goal (confidentiality, integrity, authentication, non-repudiation), the mechanism that achieves it, the algorithm, and the limitation. A table mapping goal to mechanism scores full marks almost every time.

Answer Skeleton

Scenario question (10 marks). The October CAE-II style asks you to *propose* a solution and *justify* it. Structure: restate the requirement, name the controls (TLS everywhere, a stateful firewall with default deny, a remote-access VPN with MFA, certificate management), then justify each against a specific risk in the scenario. Never just list products.

Self-test

1. What is the main function of the application layer?
2. List five HTTP status classes with one code each.
3. How does HTTP/2 remove head-of-line blocking?
4. Differentiate FTP active and passive mode, and say which works behind NAT.
5. Differentiate POP3 and IMAP.
6. Explain SMTP reply code classes 2xx, 4xx and 5xx.
7. Describe DNS resolution in six steps.
8. Name five DNS record types.
9. Differentiate recursive and iterative DNS queries.
10. State the four DHCP messages in order.
11. What address does a host self-assign when DHCP fails?
12. List six goals of cryptography.
13. Differentiate symmetric and asymmetric cryptography in five rows.
14. Do RSA for $p = 3$, $q = 11$, $e = 3$, $M = 5$.
15. Why is signing done with the private key?
16. What three properties must a cryptographic hash have?
17. Differentiate a stateless packet filter from a stateful firewall.
18. What is a DMZ and why is it used?
19. How does a VPN provide confidentiality?
20. State the three objectives of TLS.
21. What is forward secrecy?
22. Differentiate AH and ESP.
23. Differentiate IPSec transport and tunnel mode.
24. Compare SSL/TLS and IPSec in four rows.
25. Give the vulnerability of HTTP and FTP and the mitigation for each.

Answers

1. To provide network services directly to application processes, defining message syntax and dialogue rules.
2. 1xx information, 2xx success (200), 3xx redirect (301), 4xx client error (404), 5xx server error (500).
3. It multiplexes independent streams over one TCP connection with binary framing, so a blocked stream does not stall the others.

4. Active: the server opens the data connection back to the client, which a firewall blocks. Passive: the client opens it. Passive works behind NAT.
5. POP3 downloads and usually deletes, for one device. IMAP keeps mail on the server and synchronises across devices.
6. 2xx success; 4xx temporary, will be retried; 5xx permanent, bounces.
7. Stub resolver to recursive resolver, cache check, root referral, TLD referral, authoritative answer, cache and return.
8. A, AAAA, CNAME, MX, NS, TXT, PTR, SOA.
9. Recursive: the resolver does all the work and returns the final answer. Iterative: each server returns the next referral.
10. Discover, Offer, Request, Acknowledge.
11. A link-local address in 169.254.0.0/16.
12. Confidentiality, integrity, authentication, non-repudiation, access control, availability.
13. One shared key versus a key pair; fast versus slow; hard versus easy distribution; no non-repudiation versus non-repudiation; AES versus RSA.
14. $n = 33$, $\phi = 20$, $e = 3$, $d = 7$; $C = 26$; decryption returns 5.
15. Only the private-key holder could produce the signature, which gives authentication and non-repudiation.
16. One-way, collision resistant, avalanche effect.
17. A packet filter judges each packet alone by header fields; a stateful firewall tracks connections and permits return traffic automatically.
18. A screened subnet holding public servers between two firewalls, so a compromised public server does not expose the internal network.
19. It encrypts and encapsulates the original packet inside a new one that crosses the public network.
20. Confidentiality, integrity and authentication.
21. Compromise of the long-term key later does not decrypt past sessions, because ephemeral keys were discarded.
22. AH provides integrity and authentication only; ESP adds confidentiality.
23. Transport mode protects the payload and keeps the original IP header; tunnel mode encrypts the whole packet and wraps it.
24. Layer 3 versus layer 4–5; transparent to applications versus application-integrated; works over UDP versus requires TCP; VPNs versus web and mail.
25. HTTP is plaintext, fixed by HTTPS/TLS; FTP is plaintext with firewall-hostile two-port design, fixed by SFTP or FTPS.

Last-minute page

PORTS
20/21 FTP, 22 SSH, 23 Telnet
25 SMTP, 53 DNS, 67/68 DHCP
80 HTTP, 110 POP3, 143 IMAP
161 SNMP, 443 HTTPS

HTTP
stateless request/response
2xx OK, 3xx redirect,
4xx client, 5xx server
HTTP/2 streams, HTTP/3 QUIC

FTP
2 connections: control 21, data 20
active = server connects back
passive = client connects out
use SFTP instead

DNS
root → TLD → authoritative
A, AAAA, CNAME, MX, NS, TXT
recursive ask, iterative referrals

DHCP
DORA: Discover, Offer,
Request, Acknowledge
fail → 169.254.x.x

CRYPTO GOALS
confidentiality, integrity,
authentication, non-repudiation
symmetric fast, asymmetric slow
hybrid: asymmetric to agree key

SIGNATURE
hash, encrypt with PRIVATE key
verify with PUBLIC key

FIREWALL
stateless: per packet
stateful: connection table

default deny, DMZ

TLS
confidentiality, integrity, auth
certificate + key exchange
forward secrecy = ECDHE

IPSEC
AH integrity only, ESP + encryption
transport: payload
tunnel: whole packet
TRAPS: private key signs,
public key encrypts

For any scenario question, map each risk to a named control and say what the control prevents. Lists of products score nothing.